

Clase 198 — Casos de estudio de detección

Parte: **8 — Blue Team, detección y SOC** · Fuente: *The Practice of Network Security Monitoring* — Bejtlich · *Applied NSM* — Sanders y Smith 🕒 Duración estimada: **120 min** · Nivel: **Avanzado**

🎯 Objetivo

Integrar todo lo aprendido en la parte resolviendo casos realistas de detección de principio a fin: desde el compromiso inicial hasta la exfiltración, reconstruyendo la cadena de ataque con telemetría de endpoint y red, mapeándola a ATT&CK y proponiendo las detecciones que la habrían atrapado antes. Es la clase de síntesis práctica del blue team.

📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Reconstruir** una intrusión completa a partir de telemetría heterogénea.
2. **Mapear** cada fase del ataque a técnicas ATT&CK.
3. **Identificar** en qué punto cada detección habría interrumpido la cadena.
4. **Priorizar** mejoras de detección con base en los huecos observados.
5. **Comunicar** el caso con una línea de tiempo y lecciones aprendidas.

📖 Temas

#	Tema	Por qué importa
1	Método de análisis de caso	Estructura para no perderse
2	Caso 1: phishing → ejecución → persistencia	Cadena de intrusión típica
3	Caso 2: movimiento lateral → dominio	Escalada y propagación
4	Caso 3: C2 → exfiltración	Salida de datos
5	Reconstrucción de línea de tiempo	Ordenar los hechos
6	Mapeo a ATT&CK	Vocabulario y cobertura
7	Puntos de detección perdidos	Dónde mejorar
8	Lecciones aprendidas y reporte	Cerrar el ciclo

📖 Definiciones y características

- **Análisis de caso:** estudio estructurado de una intrusión para extraer detecciones y lecciones. Característica: enfoque retrospectivo con valor prospectivo.
- **Línea de tiempo (timeline):** secuencia ordenada de eventos del incidente. Característica: base de toda reconstrucción; requiere tiempo sincronizado (clase 182).

- **Cadena de ataque:** fases del compromiso (acceso inicial → ejecución → persistencia → lateral → C2 → exfiltración). Característica: cada eslabón es una oportunidad de detección.
- **Punto de detección:** momento donde una regla habría disparado. Característica: cuanto más temprano, menor el daño.
- **Pivot:** paso de un dato a otro relacionado (proceso→conexión→host). Característica: técnica central de la investigación.
- **Lección aprendida:** mejora concreta derivada del caso. Característica: debe traducirse en detección, control o proceso.

Herramientas y preparación

- Un dataset de intrusión realista: **Splunk BOTS**, **Security Onion** con PCAP/logs de ejemplo, o **EVTX-ATTACK-SAMPLES** (colección de Event Logs de ataques).
- Tu SIEM (Splunk/Elastic) para consultar la telemetría del caso.
- **ATT&CK Navigator** para el mapeo.
- Una plantilla de reporte de incidente con línea de tiempo.

Trabaja sobre datasets públicos o de tu laboratorio; no analices datos de terceros sin autorización.

Laboratorio guiado — Resuelve una intrusión completa

1. **Carga el dataset.** Importa BOTS o los EVTX de ataque en tu SIEM.
2. **Establece el punto de partida.** Localiza el acceso inicial (correo de phishing, adjunto, primer proceso anómalo) y fija el T0.
3. **Signe la ejecución.** Pivota del adjunto al proceso (Sysmon 1), a la línea de comandos y a la descarga (Event 3/proxy).
4. **Detecta persistencia.** Busca tareas programadas, Run keys o servicios creados (4698, Sysmon 13, 7045).
5. **Rastrea el movimiento lateral.** Correlaciona logons entre hosts (clase 192): PsExec/WMI/WinRM, 4624 tipo 3/10.
6. **Encuentra el C2 y la exfiltración.** Identifica beaconing (clase 193) y salida de datos anómala (clase 191).
7. **Construye la timeline.** Ordena todos los eventos con su técnica ATT&CK asociada en una tabla.
8. **Marca los puntos de detección perdidos.** Para cada fase, indica qué regla la habría atrapado y por qué no disparó (falta de telemetría, regla ausente, falso negativo).
9. **Escribe el reporte.** Resumen ejecutivo, timeline, mapeo ATT&CK y 5 mejoras priorizadas.

Ejercicios

1. Reconstruye la fase de acceso inicial de un caso con sus eventos.
2. Mapea las 6 fases de un caso a técnicas ATT&CK concretas.
3. Identifica el punto de detección más temprano posible y su regla.
4. Redacta 5 lecciones aprendidas accionables.
5. Escribe una detección nueva derivada de un hueco del caso.
6. Elabora la línea de tiempo del caso en una sola tabla.

Reto verificable

Resuelve un caso completo entregando: línea de tiempo con técnicas ATT&CK por fase, identificación de los puntos de detección perdidos y al menos tres detecciones nuevas que habrían interrumpido la cadena antes. **Criterio de aceptación:** la timeline cubre desde el acceso inicial hasta la exfiltración de forma coherente y con tiempos ordenados, cada fase está mapeada a su técnica correcta, y las detecciones propuestas son verificables (probadas o expresadas como reglas Sigma/SIEM concretas).

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Timeline desordenada	Tiempos no sincronizados; normaliza a UTC (clase 182)
Fases sin evidencia	Punto ciego de telemetría; anótalo como hueco a cerrar
Mapeo ATT&CK forzado	Técnica mal asignada; verifica el procedimiento real
"El ataque era indetectable"	Casi nunca; suele faltar una fuente o una regla, no ser imposible
Reporte sin acciones	Análisis sin lecciones; cada caso debe producir mejoras concretas

Preguntas frecuentes

? ¿Por qué estudiar casos si ya sé las técnicas? Porque la realidad mezcla fases, ruido y datos incompletos. Los casos entrenan el pivoteo, la reconstrucción y el criterio, que ninguna clase teórica da por sí sola.

? ¿Dónde consigo datos realistas para practicar? Splunk BOTS, Security Onion, EVTX-ATTACK-SAMPLES y los datasets de Atomic Red Team ofrecen telemetría de ataques reproducible y legal para entrenar.

? ¿El objetivo es encontrar al atacante o mejorar la detección? Ambos, pero el valor duradero está en las detecciones y lecciones que dejas: cada caso resuelto debe hacer al SOC más difícil de sorprender la próxima vez.

Referencias

- Bejtlich, R. *The Practice of Network Security Monitoring*. No Starch Press.
- Sanders, C. y Smith, J. *Applied Network Security Monitoring*. Syngress.
- Splunk BOTS datasets — <https://github.com/splunk/botsv3>
- EVTX-ATTACK-SAMPLES — <https://github.com/sbousseaden/EVTX-ATTACK-SAMPLES>
- MITRE ATT&CK — <https://attack.mitre.org/>

Siguiente clase

[Clase 199 - Ingeniería de detección como disciplina](#)